

HOW TO BUILD A ZERO TRUST SECURITY PROGRAM

*A practical guide to identity, devices, networks, applications, data,
workloads, visibility, automation, and governance*

Alberto (Al) Leiva

Version 1.0 - July 2026

Human safety comes first. Zero Trust should reduce risk without creating unnecessary surveillance, discrimination, or accessibility barriers.

1. What Zero Trust means

- Zero Trust is a set of principles and an enterprise architecture approach, not a single product.
- Do not grant implicit trust because of network location, device ownership, job title, or a previous successful login.
- Continuously evaluate identity, device, application, data, behavior, and environmental signals.
- Protect individual resources with explicit policy decisions and least privilege.

2. Business outcomes and governance

- Connect the program to business resilience, data protection, remote work, cloud adoption, regulatory duties, and incident containment.
- Create executive sponsorship, a cross-functional steering group, accountable pillar owners, and a documented decision process.
- Define scope, priorities, funding, dependencies, risk acceptance, exceptions, and measurable outcomes.
- Avoid treating Zero Trust as a network-only or identity-only project.

3. NIST logical architecture

- Policy Engine decides whether access should be granted, denied, or limited.
- Policy Administrator establishes or terminates the connection according to the decision.
- Policy Enforcement Point enables, monitors, and terminates access between a subject and a resource.
- Policy decisions should use identity, device, resource, threat, behavior, and organizational-policy data.

4. Current-state discovery

- Inventory users, privileged accounts, service accounts, workloads, devices, applications, data repositories, networks, APIs, SaaS, cloud resources, OT/ICS, and third parties.
- Map critical business services and their dependencies.
- Identify legacy authentication, shared credentials, unmanaged devices, public exposure, flat networks, excessive privileges, and unmonitored data flows.
- Record technology ownership, lifecycle status, and planned retirement.

5. Protect identities

- Use phishing-resistant MFA for privileged and high-risk access where feasible.
- Apply risk-based and context-aware access policies.
- Use privileged access management, just-in-time elevation, separate administrative accounts, and approval for sensitive roles.
- Manage non-human identities, secrets, certificates, API keys, and workload identities with the same discipline as human accounts.

- Remove dormant accounts and review entitlement regularly.

6. Secure devices and endpoints

- Require device inventory, ownership, supported operating systems, encryption, secure configuration, endpoint protection, and timely patching.
- Use device health and compliance as access signals.
- Separate corporate, personal, contractor, shared, server, mobile, and specialized device policies.
- Provide restricted alternatives for users who cannot use a standard managed device.
- Isolate or remediate devices that become risky during a session.

7. Protect networks and environments

- Reduce dependence on a trusted internal network.
- Segment by business service, sensitivity, workload, and risk rather than only by broad VLANs.
- Use encrypted connections, authenticated proxies, application-aware controls, DNS protection, and controlled egress.
- Limit lateral movement and administrative pathways.
- Protect remote, branch, cloud, data center, OT/ICS, and partner connections.

8. Protect applications and workloads

- Inventory applications, owners, authentication methods, data, integrations, software dependencies, and deployment paths.
- Modernize legacy applications through gateways, proxies, segmentation, or compensating controls.
- Use workload identities and short-lived credentials.
- Apply secure development, dependency scanning, code-signing, secrets management, runtime protection, and change control.
- Authorize API and service-to-service access at every request.

9. Protect data

- Discover, classify, label, and assign ownership to sensitive data.
- Apply least privilege, encryption, data loss prevention, retention, deletion, and rights management.
- Use data sensitivity as an input to access decisions.
- Monitor unusual downloads, bulk access, external sharing, and attempts to bypass controls.
- Prevent lower environments from receiving unrestricted production data.

10. Visibility, analytics, and detection

- Centralize identity, endpoint, application, cloud, network, data, and administrative telemetry.
- Normalize time, identity, device, resource, and session context.
- Detect impossible travel, token abuse, anomalous privilege use, risky devices, lateral movement, and unusual data access.

- Protect logs from alteration and define retention based on risk and privacy.
- Create feedback loops so incidents improve policies.

11. Automation and orchestration

- Automate routine enrichment, risk scoring, containment, credential revocation, device isolation, and ticket creation.
- Require human approval for actions with material business, legal, safety, or availability impact.
- Test automation in stages and provide rollback and emergency-stop procedures.
- Prevent automation from amplifying a false positive across the enterprise.

12. Third parties and remote access

- Use identity-based, application-specific access instead of broad network access where possible.
- Require named accounts, MFA, managed or verified devices, time limits, session monitoring, and sponsor approval.
- Restrict vendors to required systems and hours.
- Remove access promptly at contract end or role change.
- Include Zero Trust responsibilities in contracts and incident procedures.

13. OT, ICS, IoT, and legacy systems

- Prioritize safety and availability.
- Use passive discovery where active scanning could disrupt operations.
- Segment zones and conduits, restrict remote access, monitor protocol behavior, and protect engineering workstations.
- Use jump hosts, unidirectional gateways, allowlists, compensating controls, and planned maintenance windows.
- Do not force modern controls onto unsupported systems without engineering review.

14. Cloud and multi-cloud

- Apply consistent identity, workload, device, data, logging, and policy principles across cloud providers.
- Use cloud-native controls but maintain common governance and evidence.
- Remove public exposure, excessive roles, unmanaged keys, and overly broad trust relationships.
- Protect management planes and CI/CD pipelines.
- Continuously evaluate configuration drift and attack paths.

15. Policy design and access decisions

- Define subject, resource, action, conditions, risk, decision, enforcement, session duration, and reauthentication rules.

- Use deny-by-default for sensitive resources while avoiding rules that lock out essential or emergency operations.
- Evaluate access continuously and reduce privileges when context changes.
- Record reasons for denials and provide accessible support and appeal mechanisms.

16. Privacy, ethics, and accessibility

- Collect only signals necessary for security and define retention and access controls.
- Review workforce monitoring with legal, privacy, labor, and ethics stakeholders.
- Test policies for disproportionate impact on remote workers, contractors, travelers, people with disabilities, and users in low-connectivity locations.
- Provide transparent notices and alternative authentication or recovery methods.
- Do not use behavioral risk scores as automatic proof of misconduct.

17. Migration strategy

- Start with a high-value business service or user group rather than attempting a simultaneous enterprise replacement.
- Create dependencies, target architecture, milestones, owners, funding, test criteria, rollback plans, and decommissioning steps.
- Run old and new controls in parallel when necessary.
- Remove obsolete trust paths after validation.
- Communicate changes and train support teams before enforcement.

18. Testing and assurance

- Test authentication, authorization, device posture, segmentation, policy enforcement, logging, revocation, recovery, and emergency access.
- Perform tabletop exercises and authorized adversarial testing.
- Test stolen tokens, compromised devices, dormant accounts, excessive privileges, lateral movement, and data exfiltration scenarios.
- Verify that policy failures fail safely without causing unacceptable business disruption.
- Retest after major changes.

19. Metrics and executive reporting

- Measure resource coverage, phishing-resistant MFA adoption, managed-device coverage, privileged-access duration, segmentation coverage, stale accounts, policy exceptions, time to revoke access, lateral-movement containment, and sensitive-data exposure.
- Report business risk reduction, not only tool deployment.
- Show trends, dependencies, overdue actions, accepted risks, and decisions needed.
- Avoid vanity metrics that reward blocking legitimate work.

20. 30/60/90-day plan

- Days 1-30: establish governance, inventory critical services, identify major trust assumptions, protect privileged identities, and enable essential logging.
- Days 31-60: implement conditional access, device signals, workload identities, priority segmentation, data classification, and third-party restrictions.
- Days 61-90: automate selected responses, test high-risk scenarios, retire obsolete access paths, establish metrics, and approve the next implementation wave.

21. Maturity assessment

Pillar	Traditional	Initial	Advanced	Optimal
Identity	Passwords and broad roles	MFA for priority users	Risk-based access and PAM	Phishing-resistant, continuous, automated
Devices	Limited inventory	Basic management	Compliance-based access	Continuous posture and automated response
Networks	Flat trusted network	Priority segmentation	Application-aware segmentation	Dynamic least-privilege access
Applications	Legacy trust	SSO and inventory	Workload identities and API policy	Continuous authorization and runtime protection
Data	Location-based protection	Classification pilots	DLP and rights controls	Policy follows data and risk
Visibility	Siloed logs	Central collection	Cross-pillar analytics	Automated feedback and response

22. Production readiness checklist

- ☐ Executive sponsor and pillar owners
- ☐ Critical services and resources inventoried
- ☐ Target architecture and roadmap approved
- ☐ Phishing-resistant MFA prioritized
- ☐ Privileged access controlled
- ☐ Non-human identities governed
- ☐ Device posture used in access
- ☐ Priority segmentation implemented

- ☐ Application and API access enforced
- ☐ Sensitive data classified and protected
- ☐ Third-party access restricted
- ☐ Central telemetry and detections enabled
- ☐ Automation tested with rollback
- ☐ Privacy and accessibility review completed
- ☐ Incident and emergency-access exercises completed
- ☐ Metrics and exception reviews scheduled

23. Official references

- NIST SP 800-207 Zero Trust Architecture: <https://csrc.nist.gov/pubs/sp/800/207/final>
- NIST SP 1800-35 Implementing a Zero Trust Architecture: <https://csrc.nist.gov/pubs/sp/1800/35/final>
- NIST SP 800-207A Cloud-Native Access Control: <https://csrc.nist.gov/pubs/sp/800/207/a/final>
- CISA Zero Trust Maturity Model Version 2.0: <https://www.cisa.gov/resources-tools/resources/zero-trust-maturity-model>
- U.S. Department of Defense Zero Trust Strategy:
<https://dodcio.defense.gov/Portals/0/Documents/Library/DoD-ZTStrategy.pdf>
- Microsoft Zero Trust Guidance Center: <https://learn.microsoft.com/security/zero-trust/>

License

Copyright © 2026 Alberto (Al) Leiva. Licensed under CC BY-NC-SA 4.0.